DOSSIER TECHNIQUE

Une base de données *qui refuse de trahir.*

Stack, architecture, authentification, échanges et données : comment Moodly garantit l'anonymat au niveau le plus bas possible.



ÉQUIPE
Dany Ferreira · Lucas Fernandes
Briac Dassier · Nino Taravella

DÉPÔT
github.com/Ashuraz91z/
Moodly-Epitech

PROJET
Mood tracking anonyme
pour les équipes

00

La stack et l'architecture

Une app iPhone native, une version web, un seul serveur, et une base de données qui décide elle-même de ce que chacun peut lire.

BRIQUE	TECHNOLOGIE	RÔLE
App iPhone	Swift, SwiftUI, iOS 17	Les trois rôles. Swift Charts pour les graphes, le Keychain pour les jetons, une notification le jeudi
Serveur et web	Next.js 16, React 19, TypeScript	18 routes d'API et les pages web : questionnaire, Miroir, back-office
Base de données	Supabase (PostgreSQL)	Comptes, règles d'accès, calculs du Miroir
Tests	PGlite (PostgreSQL en mémoire)	67 vérifications de l'anonymat, sans réseau
Outils	Git, GitHub, ESLint, XcodeGen	Historique, analyse du code, projet Xcode généré

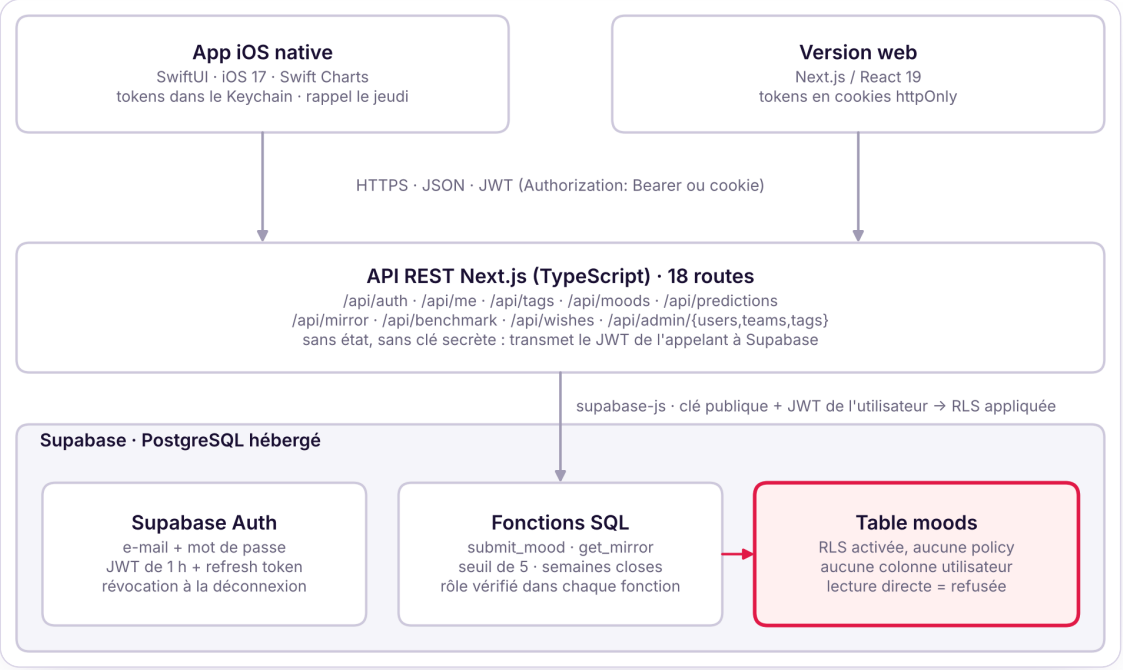


Fig. 1 Le serveur ne stocke rien et n'a aucune clé d'administration : il transmet le jeton de l'utilisateur, et la base applique ses règles à cette personne.

01

Nos choix, et ce qu'ils coûtent

Chaque choix a un prix. Nous l'avons pesé avant de nous lancer.

CHOIX	POURQUOI	ÉCARTÉ	COÛT
Anonymat appliqué par la base	Même un bug dans l'app ou le serveur ne peut pas exposer une réponse	Filtrer côté serveur ; Firebase	Logique écrite en SQL
Un serveur Next.js entre clients et base	Un seul contrat pour l'iPhone et le web ; jetons web inaccessibles au JavaScript	Accès direct depuis l'app (cadrage initial avec Expo)	Un serveur Node à héberger
SwiftUI natif	Aucune dépendance tierce, accès direct aux outils d'Apple	Expo, Capacitor	Pas d'Android pour l'instant
Semaines closes, seuil de 5	Impossible de deviner une réponse en comparant deux moyennes	Affichage en direct	Le manager attend le lundi

AUTHENTIFICATION

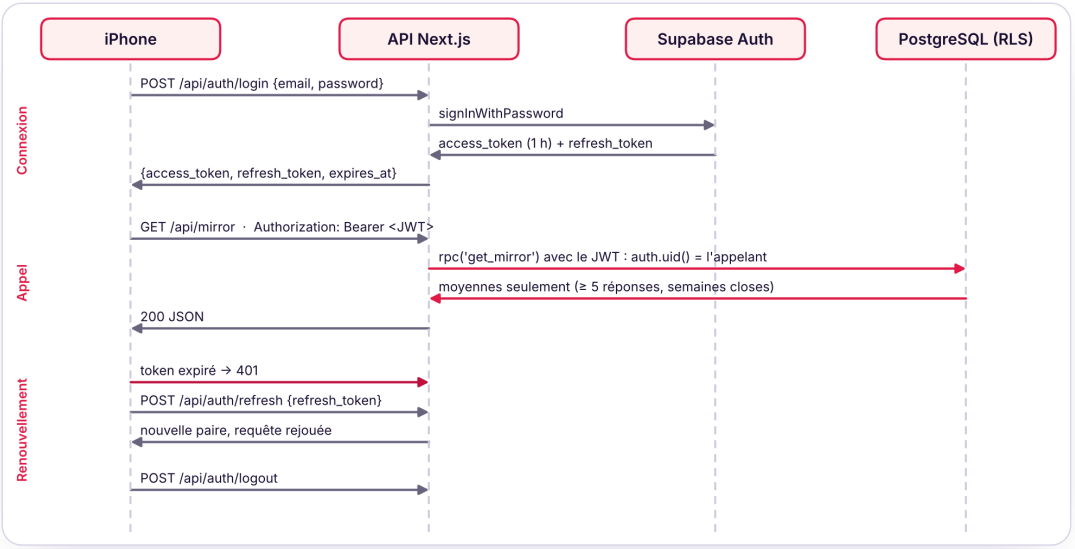


Fig. 2 Connexion, appel authentifié et renouvellement du jeton.

	APP IPHONE	VERSION WEB
Stockage des jetons	Keychain	Cookies httpOnly (invisibles pour le JavaScript)
Expiration	1 h ; un seul renouvellement automatique, puis la requête est rejouée	Identique
Déconnexion	Session révoquée côté serveur, Keychain vidé	Session révoquée, cookies supprimés

02

Échanges et données

Entre l'iPhone et le serveur, un contrat simple. Dans la base, une seule table sensible, que personne ne peut lire.

RÈGLE D'ÉCHANGE	DÉTAIL
Format	JSON, avec le jeton dans l'en-tête `Authorization` (iPhone) ou en cookie (web)
Erreurs	Toujours `{ "error": "message lisible" }` et un code clair : 400 saisie invalide, 401 non connecté, 403 mauvais rôle, 409 déjà répondu
Robustesse	Délai de 20 s, renouvellement automatique, message clair si le serveur est injoignable, adresse réglable pour les démos en réseau local

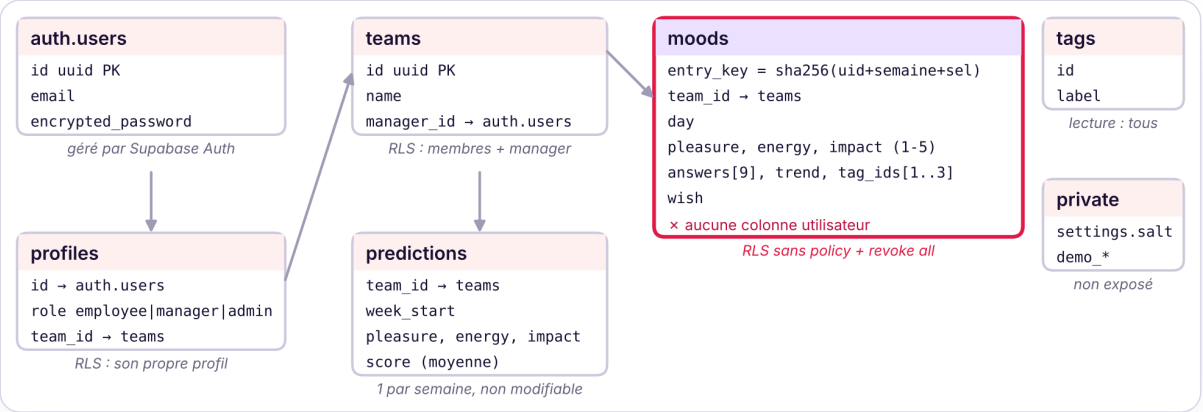


Fig. 3 Modèle de données. La table `moods` n'a aucune colonne utilisateur et aucune règle d'accès : seules des fonctions qui renvoient des moyennes peuvent la lire.

FONCTION	POUR	CE QU'ELLE GARANTIT
`submit_mood`	collaborateur	Une réponse par semaine, valeurs vérifiées, aucun identifiant enregistré
`submit_prediction`	manager	Un pronostic par semaine, impossible à modifier
`get_mirror`	manager	Rien avant le pronostic ; semaines terminées, au moins 5 réponses
`admin_*`	RH	Gestion des comptes et équipes ; agrégats uniquement, sans les pronostics

03

Qualité, sécurité, versionnage

L'anonymat n'est pas seulement décrit : il est testé à chaque modification de la base.

La commande `npm run test:db` reconstruit toute la base sur un PostgreSQL en mémoire, puis se connecte tour à tour comme Inès, son manager Thomas ou l'admin, et vérifie 67 propriétés en quelques secondes.

CE QUE LES TESTS TENTENT	RÉSULTAT ATTENDU
Inès, puis son manager, lisent directement les réponses	refusé
Inès répond deux fois la même semaine	refusé
Thomas ouvre le Miroir sans avoir pronostiqué	verrouillé
Une semaine de moins de 5 réponses, ou la semaine en cours, est publiée	jamais

MENACE	PARADE
Un manager veut savoir qui a mal répondu	Aucun nom stocké, seuil de 5, pas de texte libre
Vol de jeton	Keychain sur iPhone, cookies httpOnly sur le web, jeton d'une heure
Fuite d'une clé d'administration	Il n'y en a pas : le serveur n'utilise que la clé publique

Avant une mise en production : imposer HTTPS, utiliser une base dédiée à la démo, lancer les tests à chaque push et mettre à jour Next.js 16.4.0, qui signale une vulnérabilité connue.

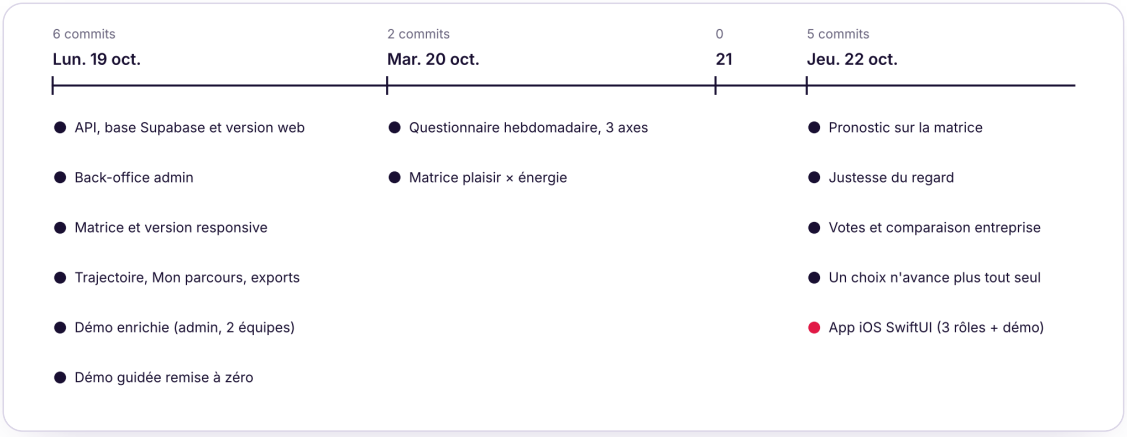


Fig. 4 13 commits du 19 au 22 octobre, un par étape. Le schéma de la base est versionné en 10 migrations numérotées, et le README documente l'installation, chaque route et les règles d'anonymat.